

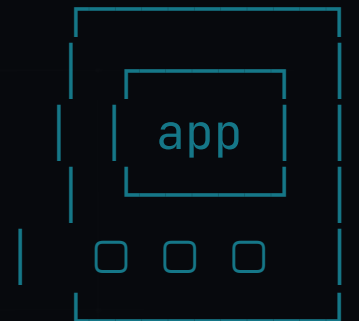
Seguridad Móvil

Android e iOS por dentro: sandbox, permisos, almacenamiento, MDM y los riesgos específicos de BYOD y apps no verificadas.

• 16 diapositivas

~22 min

Nivel · Iniciación + Práctica



sandbox
permissions
keystore

Qué vamos a ver

/01	Por qué el móvil importa	contexto
/02	Arquitectura Android vs iOS	sandbox
/03	Modelo de permisos	runtime
/04	OWASP Mobile Top 10 (2024)	catálogo
/05	Almacenamiento seguro	keystore · keychain
/06	Red · pinning, MITM, transporte	conexión
/07	Amenazas habituales	malware · sideload
/08	Tiendas y verificación de apps	Play · App Store
/09	MDM · MAM · BYOD	enterprise
/10	Buenas prácticas usuario	hábitos
/11	Lab · análisis estático de APK	manos a la obra

El móvil concentra **identidad, MFA, banca, email corporativo y geolocalización**.
Comprometerlo equivale a comprometer a la persona y, cada vez más, a la empresa.

Síntesis a partir de ENISA Threat Landscape 2024 e INCIBE [1][2]

~7,2 B

de usuarios de smartphone en el mundo · más que ordenadores personales. [3]

BYOD

extiende la red corporativa a un dispositivo no controlado por IT.

MFA

vive aquí · si cae el móvil cae el segundo factor.

Arquitectura · Android vs iOS

Android // AOSP		iOS // Apple	
base	Linux modificado · cada app corre con su propio UID .	base	XNU (Darwin) · permisos basados en entitlements firmados por Apple.
sandbox	Aislamiento por UID + SELinux obligatorio desde Android 5.	sandbox	Sandbox por app aplicada por el kernel · sin acceso al sistema.
paquete	APK firmado · zipalign · v2/v3 signature scheme.	paquete	IPA firmado · obligatorio cifrado en reposo a nivel de archivo.
verificación	Verified Boot en arranque · Play Protect en runtime.	verificación	Secure Enclave · cadena de arranque verificada.
abierto a	Sideload activable + tiendas alternativas.	abierto a	Tienda única (salvo UE con DMA · 2024).

Modelo de permisos

Android	// permission model
declaración	Listados en <code>AndroidManifest.xml</code> .
runtime	Desde Android 6 (M) · diálogo en el primer uso.
peligrosos	<code>CAMERA · LOCATION · RECORD_AUDIO · READ_CONTACTS</code>
scoped storage	Acceso restringido al almacenamiento desde Android 10.

iOS	// purpose strings
declaración	<code>Info.plist</code> · cada permiso requiere un texto explicativo (<code>NSXxxUsageDescription</code>).
runtime	Diálogo del sistema · sin alternativa para la app.
granularidad	Localización aproximada vs precisa · acceso a "fotos seleccionadas".
App Tracking	ATT desde iOS 14.5 · opt-in explícito al tracking.

OWASP Mobile Top 10 · 2024

M1	Improper Credential Use	Creds hardcoded, tokens laxos.	M2	Inadequate Supply Chain	SDKs y libs de terceros maliciosos.
M3	Insecure Auth / Authz	MFA débil, bypass por deep links.	M4	Insufficient I/O Validation	SQLi/XSS en WebViews y deep links.
M5	Insecure Communication	Sin TLS · sin pinning.	M6	Inadequate Privacy Controls	Datos personales sin base legal.
M7	Insufficient Binary Protections	Sin ofuscación ni detección de root.	M8	Security Misconfiguration	Backups, exported activities, debug.
M9	Insecure Data Storage	Datos sensibles sin cifrar.	M10	Insufficient Cryptography	DES, ECB, IV repetido, claves embebidas.

Almacenamiento seguro · keystore y keychain

Android Keystore

Almacén de claves respaldado por hardware (StrongBox/TEE).
Operaciones criptográficas sin extraer la clave nunca al espacio de usuario.

úsalo · siempre · para claves y tokens

iOS Keychain

Almacén de credenciales protegido por el Secure Enclave.
Atributos de accesibilidad: WhenUnlockedThisDeviceOnly.

úsalo · siempre · sólo lo necesario

SharedPreferences / UserDefaults

XML/plist sin cifrar legible si el dispositivo está rooteado o tras un backup. NO son almacén seguro.

prohibido · para secretos

SQLite sin cifrar / archivos planos

DBs por defecto sin cifrar. Si necesitas BD local, usa SQLCipher o Android EncryptedSharedPreferences.

prohibido · para datos sensibles

Red · TLS, pinning y MITM

[01] **TLS 1.2+ obligatorio** · iOS exige App Transport Security · Android Network Security Config por defecto. tls

[02] **Certificate pinning** · sólo aceptar un set conocido de certs/keys. Para de un proxy interceptador. pin

[03] **No deshabilitar validación** · ni en debug ni "para que tire". Es el error más común en mobile MITM. audit

[04] **Cuidado con WebView** · puede aceptar SSL roto con onReceivedSslError mal manejado. webview

[05] **VPN corporativa** en BYOD · siempre que la app maneje datos sensibles fuera de la oficina. vpn

[06] **Detecta proxies** de sistema y certificados de usuario añadidos en Android 7+ (no se confían por defecto). proxy

Amenazas habituales

Bankers Trojanos bancarios. Pantallas falsas (overlays) sobre apps reales, abuso de Accessibility Services. <i>eg. Anatsa, FluBot.</i>	Spyware comercial Pegasus, Predator. Cadenas 0-click contra periodistas y activistas. Compromiso a nivel kernel.
Sideload APKs fuera de la tienda · cracks, "premium gratis", repackaged apps con trojanos.	Smishing SMS con link a APK. "Paquete retenido", "actualiza tu banco". Pide instalar fuera de tienda.
Root / jailbreak Saltarse el sandbox. Rompe la separación entre apps y expone tokens, BD y keystore.	SIM swap Robo del número. Anula el MFA por SMS. Suplantación ante el operador con datos OSINT.

Tiendas y verificación

Play Protect // Google Escaneo automático on-device + análisis cloud · publica APIs de verificación a desarrolladores y revisa nuevos uploads.	App Review // Apple Revisión manual + automatizada por humanos antes de publicar. Más restrictivo, más lento, menos malware reportado.
F-Droid // open-source Tienda comunitaria de apps libres con builds reproducibles. Buen origen para herramientas técnicas verificables.	DMA / sideload UE // 2024 El Reglamento de Mercados Digitales abre iOS en la UE a tiendas alternativas. Cambia el modelo de confianza tradicional.
Origen desconocido // Android Sideload por APK · debe activarse por app. Origen habitual de malware. Desactivar salvo necesidad.	Enterprise // MDM Distribución privada vía MDM/MAM con catálogo controlado por IT (Intune, Jamf).

MDM, MAM y BYOD

// MDM

Mobile Device Mgmt

Gestiona **todo el dispositivo**: políticas, apps, wipe remoto. Pensado para terminales corporativos.

eg. Intune, Jamf

// MAM

Mobile App Mgmt

Gestiona **solo apps de empresa** dentro del móvil personal. Perfil de trabajo separado, wipe sólo de lo corporativo.

eg. Android Work Profile

// BYOD

Bring Your Own Device

Empleados usan su móvil personal para trabajo. Política clara, MAM y conditional access (NIST SP 800-124).

eg. correo + Teams en móvil propio

▲ Conditional access · solo se accede a recursos corporativos si el dispositivo cumple la política (cifrado, no rooteado, OS al día).

Buenas prácticas para el usuario final

[01] **Actualiza el OS** · la mayoría de exploits móviles atacan versiones sin parchear. patch

[02] **Instala sólo desde tiendas oficiales** · desactiva orígenes desconocidos. install

[03] **Bloqueo biométrico + PIN largo** · 6 dígitos como mínimo. Activa cifrado de dispositivo. lock

[04] **Revisa permisos periódicamente** · ¿por qué la linterna pide contactos? perms

[05] **MFA con app o llave, no por SMS** · resiste SIM swap. mfa

[06] **VPN en redes públicas** y desactiva "auto-conectar" a Wi-Fi conocidos. net

[07] **Activa "Buscar mi dispositivo"** · permite wipe remoto si lo pierdes. lost

Genera un proyecto Android vulnerable

```
// analyzer
Kali Linux
172.X.X.X .
sin red
```

```
~/lab-08/app/
```

```
// output
2 ficheros
manifest +
LoginActivity
```

TRES FALLOS A PROPÓSITO

- › **Permisos excesivos** en el manifest (M8).
- › **Activity exportada** sin protección (M3).
- › **Credenciales hardcoded** en código (M1).

●●● kali@kali · ~ · bash

[01] Crea el directorio de la muestra:

```
$ mkdir -p ~/lab-08/app && cd ~/lab-08/app
```

[02] Genera el `AndroidManifest.xml` con permisos excesivos:

```
$ cat > AndroidManifest.xml << 'EOF'
```

```
<manifest package="com.demo.insecure">
```

```
<uses-permission
```

```
<application android:debuggable="true"
```

```
android:allowBackup="true">
```

```
<activity android:name=".LoginActivity"
```

```
android:exported="true" />
```

</application>

</manifest>

EOF

[03] Crea un `LoginActivity.java` con credenciales hardcoded:

```
$ cat > LoginActivity.java << 'EOF'
```

```
String adminUser = "admin";
```

```
String adminPass = "P@ssw0rd!";
```

EOF

Encuentra los 3 fallos

QUÉ BUSCAR Y POR QUÉ

- › **READ_SMS / READ_CONTACTS** · privacidad · M8.
- › **android:debuggable="true"** · binario depurable en prod · M7.
- › **android:exported="true"** sin permiso · expone la activity · M3.
- › **Credenciales** incrustadas en el .java · M1.
- › Mapear cada hallazgo a su categoría **OWASP Mobile**.

kali@kali · ~/lab-08/app · bash

[04] Detecta permisos peligrosos:

```
$ grep -nE 'permission|exported|debuggable' AndroidManifest.xml
```

[05] Detecta credenciales expuestas:

```
$ grep -niE 'password|secret|api.?key|token' LoginActivity.java
```

[06] Simula análisis de APK real con `apktool`:

```
$ mkdir -p app/smali/com/demo/insecure
```

```
$ cat > app/smali/com/demo/insecure/LoginActivity.smali << 'EOF'
```

```
const-string v0, "admin"
```

```
const-string v1, "P@ssw0rd!"
```

EOF

```
$ grep -rniE 'password|secret|api.?key|const-string' app/smali/
```

5 ideas para llevarte

- /01 El móvil concentra **identidad, banca, MFA y email**. Su compromiso es total.
- /02 Android e iOS resuelven la seguridad con **sandbox + permisos runtime + arranque verificado**.
- /03 Para secretos · **Keystore (Android) y Keychain (iOS)**. Nunca SharedPreferences ni plist plano.
- /04 Red · **TLS 1.2+ y pinning**. WebViews y sideload son focos habituales de fallo.
- /05 En empresa · **MDM/MAM + conditional access**. Mejor *perfil de trabajo* que controlar el móvil personal entero.

SIGUIENTE · TEMA 09

Criptografía Básica

El motor detrás de TLS, JWT, contraseñas y firmas. Simétrica, asimétrica, hashing, KDFs y por qué no te inventes la tuya.

→ continúa en el siguiente vídeo

Para profundizar

Las dos plataformas tienen documentación oficial muy completa.
OWASP cubre lo transversal.

[1]	ENISA	Threat Landscape 2024 · enisa.europa.eu
[2]	OWASP MAS	Mobile Application Security Project · Mobile Top 10 2024 · MASTG · owasp.org/Mobile-Top-10
[3]	Apple	Platform Security Guide · Keychain Services · App Review Guidelines · apple.com/security
[4]	Google / Android	Android Security Internals · Keystore System · Network Security Configuration · developer.android.com
[5]	NIST	SP 800-124 Rev. 2 · <i>Guidelines for Managing the Security of Mobile Devices</i>
[6]	INCIBE / CCN-CERT	Guías móviles y BYOD · incibe.es · ccn-cert.cni.es